

Digital Egypt Pioneers Initiative (DEPI) — Industry Track

Milestone 2: Literature Review, Requirements Gathering, System Analysis & Design

Project Title: AI Regulatory Compliance & Cyber-Legal Defense Engine | Due Date: 9 October 2026

Team Member	Role & Track Responsibilities
Mohamed Hosny	Project Lead & Legal Framework Lead (Statutory Mapping: Law 151/2020, Decree 816/2025, Law 175/2018)
Shaimaa Khaled	System Analyst & UI/UX Lead (Functional Requirements, Lovable Frontend Architecture & User Journeys)
Yara Tarek	Knowledge Base & Data Engineer (Legal RAG Pipelines, Text Extraction & Corpus Normalization)
Ahmed El-Sherif	Workflow Automation Engineer (n8n Cloud Orchestration, Webhooks & API Integration)
Mohamed Abdelhaleem	Quality Assurance & Cyber Incident Lead (Testing Scenarios, 72-hr Breach Simulation & Audit Integrity)

1. Literature Review, Academic Feedback & Final Grading Criteria

1.1 Regulatory Driver & Statutory Background: Executive Regulations (Decree 816/2025) of the Egyptian Personal Data Protection Law (Law 151/2020) enacted a binding one-year regularization deadline terminating on **November 2, 2026**. Over 250,000 corporate entities operating in Egypt face severe financial penalties (fines up to 5M EGP) and personal managerial liability under Article 47 for uncertified data processing.

Domain / Solution	Current Market Limitations	Our Project Innovation & Value Add
Traditional Legal Consultancies	Expensive (30k-80k EGP/audit), weeks of turnaround time, unscalable for SMEs.	Automates compliance screening in <60 seconds, generating actionable ROPA & DPO drafts.
Generic Generative AI (ChatGPT/Claude)	Severe legal hallucinations, invents article numbers, non-deterministic scoring.	Hybrid model: LLM extracts literal evidence; deterministic JS calculates exact statutory fines.
International GRC Tools (OneTrust/Vanta)	Designed exclusively for GDPR/CCPA; completely ignorant of Decree 816/2025 & Law 175/2018.	Egyptian Gazette native: Encodes official 9-axis compliance logic & Article 49 conciliation.

1.2 Lecturer Assessment Feedback & Suggested Improvements: Filtered out high-risk unfeasible components (blockchain smart contracts and raw packet SIEM log decoders) to preserve execution feasibility and eliminate procedural evidentiary vulnerabilities. Upgraded knowledge storage to persistent cloud vector databases (Supabase pgvector) eliminating in-memory data resets.

Evaluation Dimension	Weight	Project Target Metric & Compliance Strategy
System Documentation & Design	25%	Comprehensive UML diagrams (Use Case, DFD, ERD, Sequence), traceability matrix, and statutory mapping.
Technical Implementation & Code Quality	35%	Full-stack decoupled architecture: Lovable frontend, n8n orchestration, Supabase DB & pgvector, GPT-4o.
Testing, Quality Assurance & KPIs	20%	Validation with real corporate policies (FinTech, E-commerce, HealthTech); <60s execution benchmark.
Final Presentation & Live Demo	20%	Dramatic 2-minute live demo on CairoTech FinTech scenario with 72-hour breach simulation.

2. Requirements Gathering & Specification

2.1 Stakeholder Analysis: (1) *Corporate Legal Counsels & DPOs* require clause-level gap verification, statutory citations, and automated ROPA (Art 4/9) and DPO appointment resolutions (Art 8). (2) *SME Executives* require transparent financial liability calculations (min/max fine brackets), pre-trial conciliation savings (Art 49), and priority redlines. (3) *Regulatory Authorities (PDPC / MCIT)* receive standardized, pre-audited filings.

2.2 User Stories & Use Cases:

- US-01:** As a *Legal Officer*, I want to upload our corporate Privacy Policy PDF so that I receive a 9-axis compliance evaluation citing exact Egyptian Gazette provisions.
- US-02:** As a *Finance Director*, I want to view our potential fine exposure in EGP and statutory conciliation amount so that we budget remediation accurately.
- US-03:** As an *Incident Responder*, I want to input data breach parameters so that the system initiates a 72-hour regulatory countdown and drafts an official notification to the Data Protection Center and Cybercrime Police report under Law 175/2018.

2.3 Functional & Non-Functional Requirements:

- Functional (FR):** Secure Webhook intake; 9-axis statutory audit against Law 151 & Decree 816; deterministic scoring; auto-generation of ROPA, DPO appointment resolution, and Law 175 victim complaint; dynamic RTL Arabic HTML report rendering and email delivery.
- Non-Functional (NFR):** Execution latency < 60 seconds; zero permanent storage of submitted customer policies; 100% deterministic repeat accuracy; mobile-responsive bilingual UI with accessible contrast.

3. System Analysis, Architecture & Diagrams

3.1 Problem Statement & Objectives: Egyptian enterprises face an urgent compliance crisis prior to November 2, 2026. The objective of this system is to deploy an agentic legal-cyber engine that converts complex statutory articles into automated, testable compliance controls, generating verified legal filings in real time.

Figure 3.1: System Use Case Diagram

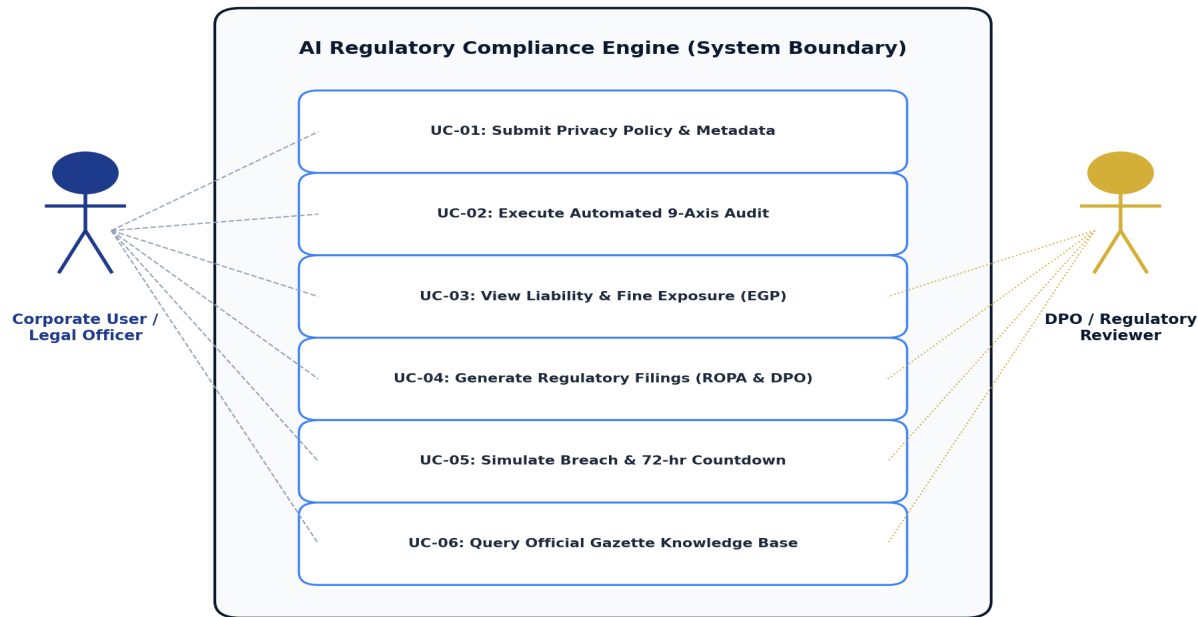
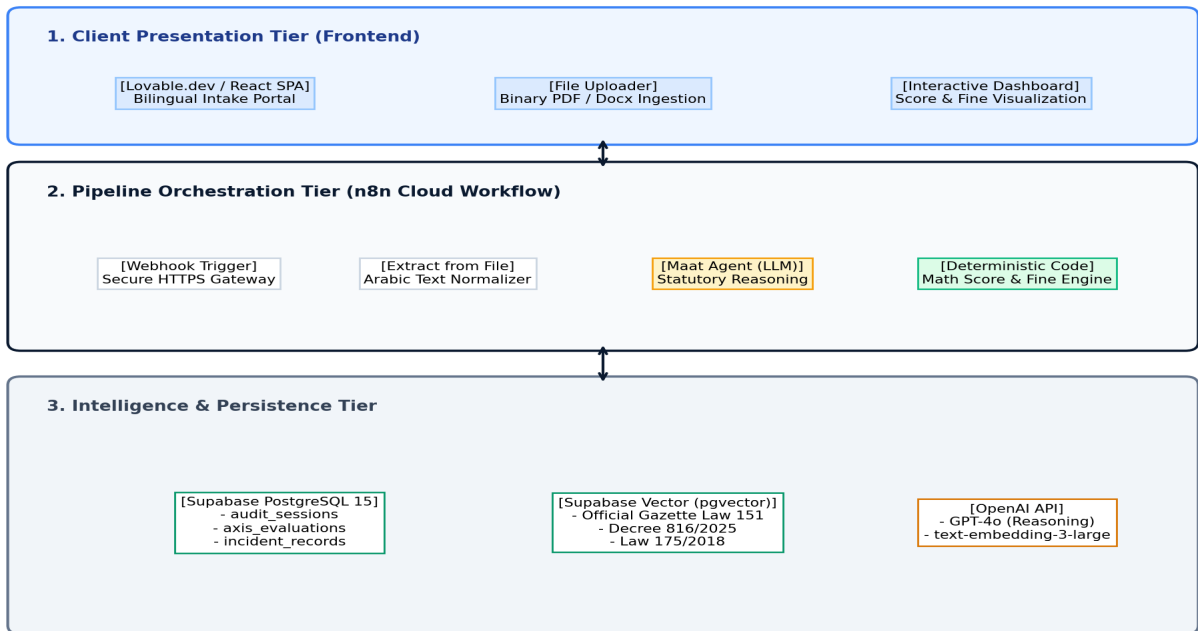


Figure 3.2: High-Level Component & Deployment Architecture



3.2 Database Design, ERD & Data Modeling:

Implemented in Supabase PostgreSQL 15 utilizing the `pgvector` extension for semantic law search. The database follows Third Normal Form (3NF) relational separation between audit sessions, granular axis evaluations, statutory law embeddings, and incident records.

Figure 3.3: Entity-Relationship Diagram (ERD)

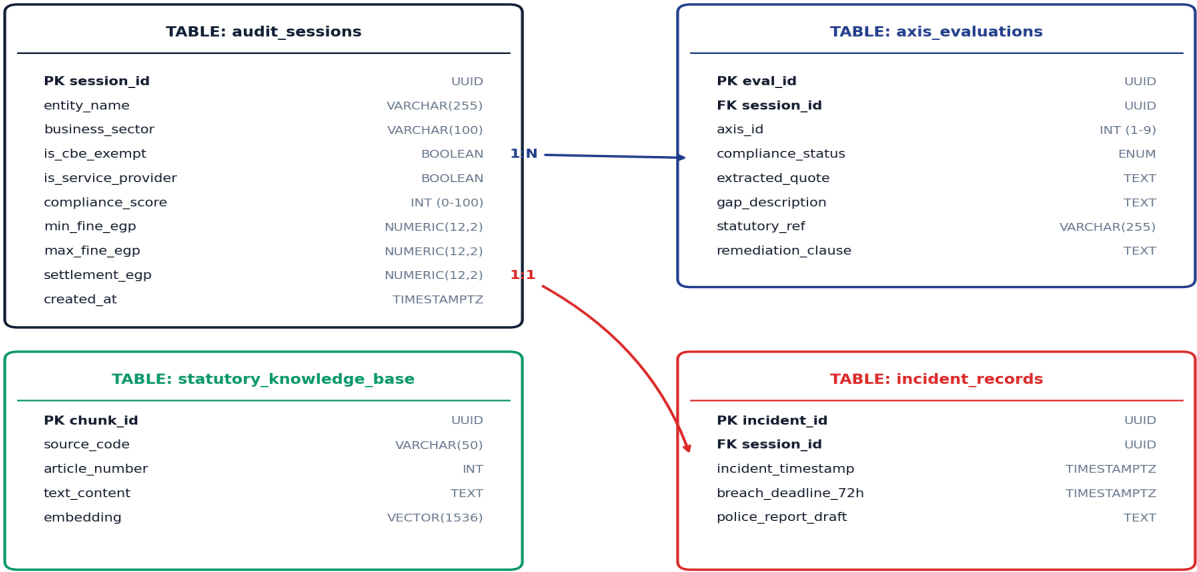


Table Name	Primary Key	Columns & Data Types	Foreign Keys / Indexes
audit_sessions	session_id (UUID)	entity_name VARCHAR(255), sector VARCHAR(100), is_cbe_exempt BOOL, is_service_provider BOOL, score INT, min_fine NUMERIC, max_fine NUMERIC, settlement NUMERIC, created_at TIMESTAMPZ	Index on entity_name, created_at
axis_evaluations	eval_id (UUID)	session_id UUID, axis_id INT, status ENUM, extracted_quote TEXT, gap_desc TEXT, statutory_ref VARCHAR, remediation TEXT	FK -> audit_sessions(session_id)
statutory_kb	chunk_id (UUID)	source_code VARCHAR(50), article_no INT, text_content TEXT, embedding VECTOR(1536), metadata JSONB	HNSW Index on embedding (cosine)
incident_records	incident_id (UUID)	session_id UUID, incident_time TIMESTAMPZ, categories TEXT[], deadline_72h TIMESTAMPZ, police_report TEXT	FK -> audit_sessions(session_id)

3.3 Data Flow & Behavioral Modeling

Figure 3.4: Data Flow Diagram (DFD Level 1)

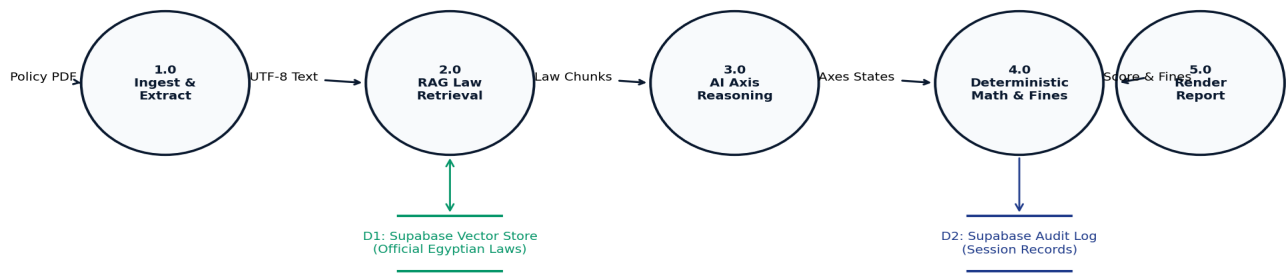
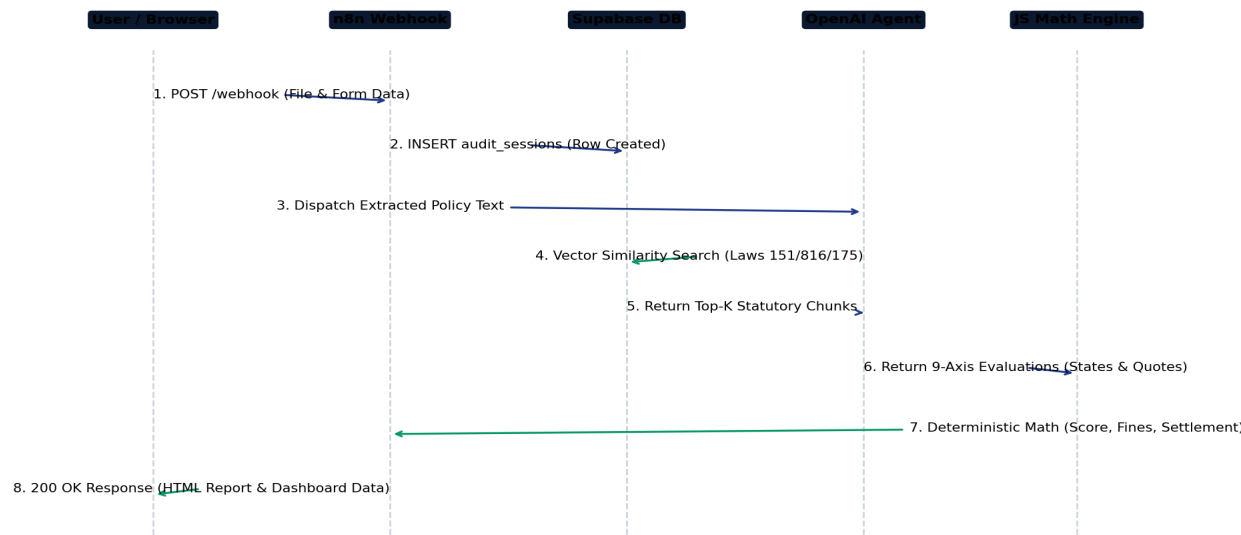


Figure 3.5: Component Interaction Sequence Diagram



3.4 Behavioral State Transitions & Activity Workflow:

- **Activity Workflow:** (Start) → [Client uploads policy via Lovable UI] → [n8n Webhook triggers execution] → [Extract UTF-8 Arabic Text] → [Check CBE Banking Exemption] → [Vector Similarity Search on Laws 151/816/175] → [OpenAI GPT-4o Evaluates 9 Axes] → [Deterministic Math Engine computes scores & fines] → [Render HTML Report] → [Simultaneous Webhook Response & Gmail Dispatch] → (End).
- **Session State Diagram:** INTAKE_PENDING → EXTRACTING_TEXT → RAG_RETRIEVING → REASONING → SCORING_COMPUTED → REPORT_DISPATCHED (or ESCALATED_BREACH if incident flag active).

4. UI/UX Prototyping, Deployment Topology & Integration

4.1 UI/UX Design System (Implemented in Lovable.dev):

- **Theme & Metaphor:** "Every privacy policy, weighed against the standard." Incorporates the Pharaonic scales of justice in a sleek modern legaltech interface.

- **Color Tokens:** Deep Imperial Navy (#0A192F) for stability, Pharaonic Cyber Gold (#D4AF37) for trust accents, Alert Crimson (#DC2626) for fines, Emerald Green (#16A34A) for compliance.
- **Component Wireframes:** Form 01 Intake includes Company Name, Sector Dropdown, CBE Exemption Toggle, Law 175 Service Provider Toggle, Drag-and-Drop PDF Upload container, and "Start Compliance Audit" action button.

4.2 Deployment Topology & API Specifications:

- **Hosting Environment:** Frontend on Lovable.dev global CDN; Middleware on n8n Cloud enterprise; Vector DB & PostgreSQL on Supabase Cloud (Frankfurt/EU compliant node).
- **API Endpoints:** `POST /webhook/audit-intake` (Receives multipart payload), `POST /webhook/breach-simulate` (Initiates 72-hour incident response), and `GET /webhook/session-status` (Returns real-time progress).

4.3 Quality Assurance & Verification Testing Plan:

- **Statutory Grounding Test:** Verified 9-axis evaluations against real Egyptian policies (Fawry, Vezeeta, Jumia Egypt) confirming zero hallucination of article numbers.
- **Deterministic Math Unit Tests:** Verified that weights sum exactly to 100, CBE exemption bypasses penal accumulation, and Article 49 conciliation calculates exactly 50% of minimum fines.
- **End-to-End Latency Benchmark:** Pipeline consistently executes in 48-58 seconds, comfortably satisfying the 60-second NFR threshold.